

Compromised agent keys keep paying.

Rebind makes revoke real. The old key dies on the next request. The new key pays only after a fresh human verification.

Revoke is recorded. The paygate never reads it.

AgentBook has no revocation operation. A compromised wallet can still resolve.

worldcoin/agentkit #37 — RFC for revoke and rotation. The contract cannot express revoke.

worldcoin/agentkit #23 — unregister hits ALREADY_REGISTERED. There is no unregister.

That is the motivation. The product is an app-layer deny and rotate list in front of a paid grant.

Mark the key revoked. The grant still returns 200.

REGISTRY

Key K

REVOKED

SAME SIGNED REQUEST

Open session, and a fresh request

GRANTED

REVOKE_INEFFECTIVE

The next request re-reads the registry. The session cookie is not enough.

AFTER REVOKE(K)

Session still open

403 revoked

FRESH SIGNATURE, NO COOKIE

checkedRevoke true

403 revoked

REVOKE_ENFORCED

K becomes K2. Without a rebind, K2 cannot pay.

OLD KEY K

Replaced, or already revoked

403

NEW KEY K2

worldRebind is empty

403 rebind required

The human finishes the journey. The server checks the result. Then K2 pays.

- 1 Start a rebind for K2.
- 2 Denied, expired, or cancelled: no grant.
- 3 A client that says “validated” changes nothing.
- 4 The server stores the subject, then the paid grant returns 200.

Say this, then stop.

Revoke is enforced on every grant.

Rotate needs a fresh human verification before the new key can pay.

That verification is World ID for Agents, checked on the server.

App-layer policy. Not a mainnet AgentBook opcode. Not login. Not a free trial.